



UNIVERSIDAD DE CHILE
FACULTAD DE CIENCIAS FÍSICAS Y MATEMÁTICAS
DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

DISEÑO Y DESARROLLO DE SISTEMA DE EVALUACIÓN AUTOMÁTICO DE
EJERCICIOS DE SEGURIDAD OFENSIVA

MEMORIA PARA OPTAR AL TÍTULO DE
INGENIERO CIVIL EN COMPUTACIÓN

DYLAN NICOLÁS RIQUELME VERGARA

PROFESOR GUÍA:
EDUARDO RIVEROS ROCA

MIEMBROS DE LA COMISIÓN:
NOMBRE COMPLETO UNO
NOMBRE COMPLETO DOS
NOMBRE COMPLETO TRES

SANTIAGO DE CHILE

2026

Resumen

PENDIENTE PENDIENTE PENDIENTE

PENDIENTE PENDIENTE PENDIENTE

Agradecimientos

- Cami
- Familia
- Amigos Colegio
- Amigos Universidad
- Eduardo
- CLCERT
- DCC
- Maribel
-

Tabla de Contenido

1. Introducción	1
1.1. Objetivos	2
1.1.1. Objetivo General	2
1.1.2. Objetivo Específicos	2
1.2. Evaluación	2
1.3. Solución Propuesta	3
1.3.1. Arquitectura General	3
1.3.2. Flujo principal	3
2. Estado del Arte	5
2.1. Plataformas Comerciales	5
2.2. Plataformas con Validación Automática	5
2.3. Plataformas de Estáticas	5
2.4. Plataformas de Tipo CTF	6
2.5. Plataformas Avanzadas	6
2.6. Oportunidad Identificada	6
2.6.1. Valor Pedagógico	7
2.6.2. Contribución Técnica	7
3. Diseño	8
3.1. Arquitectura de Capas	8
3.1.1. Justificación	8

3.1.2.	Descripción de Capas	11
3.2.	Contratos entre Capas	13
3.2.1.	Capa 1 → Capa 2: Estado Observable	13
3.2.2.	Capa 2 → Capa 3: Eventos Estructurados	14
3.2.3.	Capa 3 → Capa 4: Resultados de Evaluación	15
3.2.4.	Capa 4 → Capa 1: Ciclo de Vida	16
3.2.5.	Educador → Capa 3: Archivo YAML del Escenario	17
3.3.	Modelo de Datos	20
3.4.	Aislamiento de Entornos	21
4.	Implementación	22
4.1.	Stack Tecnológico	22
4.1.1.	Lenguaje y gestión de dependencias	22
4.1.2.	Capa 1: virtualización de entornos	22
4.1.3.	Capa 2: monitoreo pasivo	23
4.1.4.	Capa 3: motor de evaluación	23
4.1.5.	Capa 4: administración	23
4.1.6.	Testing	24
4.1.7.	Resumen del stack	24
4.1.8.	Consideraciones de evolución	24
4.2.	Decisión de Tecnología de Virtualización	25
4.2.1.	<u>Alternativas evaluadas</u>	25
4.2.2.	<u>Comparación ponderada</u>	26
4.2.3.	<u>Decisión: Docker <i>rootless</i> con interfaz abstracta</u>	26
4.2.4.	<u>Trabajo futuro en aislamiento</u>	27
4.3.	Capa 1: Orquestador de Contenedores	27
4.3.1.	<u>Detección del socket Docker</u>	27
4.3.2.	<u>Identificación y etiquetado de recursos</u>	27

4.3.3.	<u>Creación con <i>rollback</i></u>	28
4.3.4.	<u>Estrategia de <i>baseline</i> para los monitores</u>	28
4.4.	Capa 2: Monitoreo Pasivo	29
4.4.1.	Limitaciones del Monitoreo por Polling	29
4.4.2.	Monitor de Red	29
4.5.	Capa 3: Motor de Evaluación	30
4.6.	Capa 4: Administración	31
5.	Validación	32
5.1.	Evaluación	32
6.	Conclusión	33
	Apéndice A. Anexo	36

Índice de Tablas

2.1.	Comparación de plataformas de aprendizaje en ciberseguridad.	6
4.1.	Componentes del <i>stack</i> tecnológico de FlexiPwn.	24
4.2.	<u>Comparación ponderada de tecnologías de virtualización.</u>	26

Índice de Ilustraciones

3.1. Arquitectura de cuatro capas de FlexiPwn.	11
--	----

Capítulo 1

Introducción

Actualmente, la seguridad en el desarrollo de software es fundamental. Sin embargo, las malas prácticas y la falta de conocimiento siguen existiendo a pesar del aumento de amenazas y la mejora continua de capacidades de los atacantes.

Existe abundante literatura respecto a las vulnerabilidades con las que se puede encontrar un desarrollador, como el OWASP Top 10 [1], que cataloga las vulnerabilidades de software más críticas, incluyendo inyección, pérdida de control de acceso, fallas criptográficas, entre otras. Sin embargo, la mejor forma de conocer el riesgo real de las vulnerabilidades es entendiendo cómo funcionan, para lo cual un enfoque práctico permite validar su correcto entendimiento. Las investigaciones demuestran que el aprendizaje práctico es significativamente más efectivo, con estudios mostrando que los participantes retienen el 75 % de la información a través de práctica *hands-on*, comparado con solo el 5 % mediante métodos teóricos tradicionales [2].

El problema a abordar en este trabajo es facilitar, tanto al equipo docente como a los estudiantes, confirmar sus conocimientos teóricos a partir de una plataforma automatizada que valide sus avances. Las y los desarrolladores necesitan entornos controlados y seguros donde puedan experimentar y explorar vulnerabilidades posibles dentro de una aplicación sin que esta sea de producción. Para ello, se diseña y desarrolla un sistema de evaluación automático de ejercicios de ciberseguridad ofensiva.

Este proyecto se aproxima al problema desde tres perspectivas complementarias. Desde lo **pedagógico**, se requiere una forma de evaluar el progreso que capture la trayectoria completa del aprendizaje, no solo el resultado final. La validación automática basada en el estado del sistema permite registrar cada paso del estudiante durante el ataque, proporcionando trazabilidad real del proceso de aprendizaje sin recurrir a soluciones artificiales como múltiples *flags* intermedias. Desde lo **técnico**, existe una oportunidad de contribuir al ecosistema de herramientas *open source* de detección de intrusiones, publicando código, patrones y metodologías que permitan que la comunidad académica evalúe y mejore estos enfoques. Desde lo **personal**, este proyecto representa la oportunidad de desarrollar experiencia práctica en el diseño e implementación de sistemas complejos con múltiples componentes, arquitecturas de capas bien definidas, y desafíos de observabilidad cercanos a los que enfrenta la industria de ciberseguridad.

1.1. Objetivos

1.1.1. Objetivo General

Desarrollar una plataforma educativa autohospedable que permita crear entornos de práctica de seguridad ofensiva personalizables, con validación automática del progreso basada en estado de los sistemas comprometidos, facilitando el aprendizaje práctico de vulnerabilidades sin depender de validaciones manuales.

1.1.2. Objetivo Específicos

1. Diseñar e implementar una arquitectura modular que permita desplegar y gestionar múltiples entornos vulnerables simultáneamente mediante tecnologías de virtualización, asegurando aislamiento y facilidad de configuración.
2. Desarrollar un sistema de configuración declarativa que permita definir las condiciones de éxito de un ejercicio mediante archivos YAML, haciendo que la plataforma sea accesible incluso a educadores sin conocimiento técnico profundo.
3. Implementar el motor de validación automática que evalúe el estado de los sistemas comprometidos, determinando el progreso sin depender de *flags* predefinidas, ya sea por archivos modificados, servicios comprometidos, usuarios creados, entre otros.
4. Crear herramientas de seguimiento del progreso, acceso a enunciados de ejercicios y administración del sistema para educadores y estudiantes, implementadas inicialmente mediante línea de comandos.
5. Poner la plataforma a disposición del laboratorio de ciberseguridad CLCERT para su evaluación en una instancia real de uso.

1.2. Evaluación

La forma de evaluar este trabajo será verificando la capacidad del sistema para generar diferentes tipos de ejercicios con validación automática. El trabajo se considerará exitoso si es posible crear ejercicios de seguridad ofensiva con validación automática para al menos tres categorías entre: aplicaciones y servicios web, bases de datos, *pwning*, análisis forense e ingeniería reversa. Se entenderá por validación automática aquella que marca el ejercicio como completado automáticamente cuando el participante logra explotar una vulnerabilidad, acceder a un archivo específico, comprometer un servicio u obtener privilegios de usuario, sin requerir la entrada manual de *flags* o códigos predefinidos.

1.3. Solución Propuesta

La solución consiste en una plataforma que permite a los educadores cargar imágenes de sistemas vulnerables y definir reglas de validación mediante archivos YAML, generando automáticamente entornos de práctica personalizados con validación automática.

1.3.1. Arquitectura General

El sistema implementa una arquitectura dividida en cuatro capas con responsabilidades claramente delimitadas. Esta arquitectura emergió del análisis de pruebas de concepto desarrolladas durante el trabajo previo al semestre, donde se identificó que la separación de responsabilidades entre el sistema vulnerable, el mecanismo de detección y la lógica de evaluación es fundamental para lograr flexibilidad y extensibilidad.

Capa 1 — Sistemas virtualizados Contiene en estado virtualizado todos los sistemas y redes que componen el escenario de ataque. Se divide en dos subcapas: la Capa 1a representa el sistema vulnerable objetivo, mientras que la Capa 1b proporciona el entorno atacante desde el cual el estudiante ejecuta el ataque.

Capa 2 — Monitoreo pasivo Observa pasivamente el estado de los contenedores con acceso de lectura externo al sistema. Su única responsabilidad es generar un registro estructurado de eventos detectables: modificaciones del sistema de archivos, procesos creados, entradas de log, entre otros. Su comportamiento es análogo al de un SIEM (Security Information and Event Management) dedicado al escenario de ataque.

Capa 3 — Motor de evaluación Consume los eventos generados por la Capa 2 y evalúa reglas declarativas definidas en archivos YAML que especifican las condiciones de victoria. Determina automáticamente cuándo un participante ha completado objetivos sin requerir la entrada manual de *flags*.

Capa 4 — Administración Gestiona el ciclo de vida completo de los entornos de práctica y mantiene registro del progreso de todos los participantes. Proporciona interfaces para que educadores y estudiantes interactúen con el sistema mediante línea de comandos.

1.3.2. Flujo principal

1. **Carga de escenarios:** el educador entrega una imagen del sistema vulnerable junto con un archivo YAML que define los objetivos del ejercicio, las condiciones de validación y los criterios de éxito.
2. **Generación de entornos:** la plataforma instancia la imagen proporcionada, creando un entorno aislado por cada participante que intentará explotar la vulnerabilidad.
3. **Validación automática:** el motor de validación examina constantemente el estado del contenedor, comparando el estado actual contra las reglas definidas en el archivo YAML.

4. **Gestión:** tanto educadores como estudiantes utilizan herramientas de línea de comandos para interactuar con sus respectivos entornos y monitorear el avance.

Capítulo 2

Estado del Arte

En la actualidad existe una amplia variedad de plataformas que apoyan el aprendizaje en ciberseguridad. La mayoría recurre a la ludificación con el objetivo de facilitar el entendimiento mediante ejercicios prácticos, tanto de seguridad ofensiva como defensiva.

2.1. Plataformas Comerciales

Entre las plataformas comerciales más reconocidas están TryHackMe (THM) [3] y Hack The Box (HTB) [4], las cuales poseen contenido de alta calidad y ofrecen cursos y certificaciones en ciberseguridad. Ambas comparten el método de conexión a entornos hospedados por ellos y validación de *flags* para sus módulos de aprendizaje, lo que eventualmente facilita la trampa si no se toman precauciones adecuadas.

2.2. Plataformas con Validación Automática

PortSwigger Web Security Academy [5] es una plataforma que se especializa en enseñar seguridad de aplicaciones web. Es de las pocas que incluye un sistema automático para detectar avances al explotar una vulnerabilidad, sin requerir validación manual mediante *flags*. No obstante, no es autohospedable y está enfocada exclusivamente a vulnerabilidades web no personalizables.

2.3. Plataformas de Estáticas

Damn Vulnerable Web Application (DVWA) [6] es un buen método para aprender seguridad web, pero no tiene capacidad de generar escenarios personalizados de forma directa ni seguimiento de progreso, y se valida con mensajes simples al explotar cierta vulnerabilidad.

2.4. Plataformas de Tipo CTF

CTFd [7], RootTheBox [8] y picoCTF [9] son herramientas para preparar competencias de captura la bandera (*capture the flag*), con roles pedagógicos como el del curso CC5325 Taller de Hacking Competitivo. Sin embargo, para validar un ejercicio resuelto también requieren ingresar *flags* manualmente, permitiendo posibles copias entre estudiantes.

2.5. Plataformas Avanzadas

Existen opciones más complejas como CyberRangeCZ [10], EDURange [11] o Tectonic [12] para simular campos de entrenamiento de ciberseguridad (*cyber ranges*), los cuales requieren mayor conocimiento de infraestructura técnica, lo que los hace opciones poco accesibles para contextos educativos pequeños.

2.6. Oportunidad Identificada

El análisis comparativo presentado en la Tabla 2.1 demuestra que no existe una solución que integre validación automática basada en estado del sistema, sea autohospedable y sea completamente personalizable. Esta combinación es un aporte relevante para quien desee generar instancias de aprendizaje de seguridad ofensiva de forma rápida, donde baste cambiar la imagen del sistema para modificar completamente el objetivo de la actividad.

Para facilitar la comparación, se establecieron cuatro criterios clave: **Autohospedable** se refiere a la capacidad de instalar y ejecutar la plataforma en infraestructura propia; **Gratuito** indica si se puede usar sin costo (*Freemium* implica funcionalidades limitadas gratuitas); **Validación** describe el método para verificar ejercicios completados; y **Personalizable** evalúa la capacidad de crear contenido propio.

Tabla 2.1: Comparación de plataformas de aprendizaje en ciberseguridad.

Plataforma	Autohospedable	Gratuito	Validación	Personalizable
TryHackMe	No	Freemium	Flags	No
Hack The Box	No	Freemium	Flags	No
PortSwigger	No	Gratuito	Automática	No
DVWA	Sí	Gratuito	Manual	Limitado
CTFd	Sí	Gratuito	Flags	Sí
RootTheBox	Sí	Gratuito	Flags	Sí
picoCTF	Sí	Gratuito	Flags	Sí
CyberRangeCZ	Sí	Gratuito	Multicriterio	Sí
EDURange	Sí	Gratuito	Multicriterio	Sí
Propuesta	Sí	Gratuito	Automática	Sí

2.6.1. Valor Pedagógico

La validación automática basada en estado ofrece ventajas pedagógicas significativas sobre los sistemas tradicionales de *flags*. Mientras que las *flags* solo indican si un estudiante alcanzó un objetivo final, un sistema de monitoreo de estado registra la evolución completa del ataque: qué servicios enumeró, qué vulnerabilidades intentó explotar, o qué archivos modificó. Esta trazabilidad permite a los educadores entender no solo si un estudiante tuvo éxito, sino **cómo** lo logró, detectar dificultades comunes y proporcionar retroalimentación más específica y formativa.

2.6.2. Contribución Técnica

Este trabajo contribuye al ecosistema de herramientas de detección de intrusiones *open source*. Los sistemas comerciales de detección (IDS/IPS) suelen mantener sus reglas como propiedad intelectual cerrada, impidiendo que la comunidad los evalúe y mejore. Un proyecto educativo que implemente detección basada en reglas declarativas, con código completamente abierto y auditable, permite que investigadores y profesionales estudien, adapten y evolucionen estos enfoques.

Capítulo 3

Diseño

Este capítulo describe las decisiones de diseño del sistema FlexiPwn, incluyendo la arquitectura de capas, los contratos entre ellas, el modelo de datos y el modelo de aislamiento de entornos.

3.1. Arquitectura de Capas

3.1.1. Justificación

La decisión de estructurar el sistema en capas responde a principios arquitectónicos que se identificaron como necesarios a partir de las pruebas de concepto desarrolladas previo al semestre. Las limitaciones encontradas convergieron hacia un patrón común: la mezcla de responsabilidades entre el sistema a vulnerar, el mecanismo de detección y la lógica de evaluación resultaba en implementaciones frágiles, poco extensibles y fuertemente acopladas a tecnologías específicas. A partir de este análisis emergieron cuatro principios que fundamentan la arquitectura de cuatro capas.

Separación de responsabilidades

Cada capa tiene una función específica y bien definida, lo que facilita el desarrollo, *testing* y mantenimiento independiente de cada componente. Esta separación permite trabajar en capas distintas sin interferencia, y simplifica la depuración cuando surgen problemas. En las pruebas de concepto previas, la generación de eventos y la evaluación de condiciones de éxito convivían en el mismo módulo, lo que hacía que agregar un nuevo tipo de fuente de eventos o cambiar la lógica de evaluación requiriera modificar el mismo archivo, aumentando el acoplamiento y la fragilidad del sistema. En FlexiPwn, estas responsabilidades están explícitamente separadas: la Capa 2 solo observa y genera eventos, la Capa 3 solo evalúa condiciones, y ninguna de las dos modifica el estado de los entornos.

Reutilización y flexibilidad

Al abstraer las capas inferiores mediante interfaces bien definidas, el sistema puede soportar múltiples tecnologías de virtualización sin modificar las capas superiores de validación y administración. Esto permite adaptar el sistema a diferentes contextos e infraestructuras. La interfaz abstracta `EnvironmentProvider` encapsula toda la complejidad necesaria para distintas tecnologías de virtualización, como Docker *rootless*: cambiar la tecnología de virtualización solo requiere implementar esa interfaz en una nueva clase, sin tocar el motor de evaluación ni la *CLI* de administración. Por ejemplo, una futura implementación `PodmanProvider` o `KVMPProvider` no tendría impacto en las capas 3 y 4.

Extensibilidad

Nuevos tipos de validaciones o métodos de monitoreo pueden agregarse a las capas 2 y 3 sin modificar los sistemas vulnerables ni la administración. Por ejemplo, agregar soporte para detectar exfiltración de datos mediante DNS *tunneling* solo requiere modificar la Capa 2 para capturar ese tipo de eventos y la Capa 3 para evaluar las reglas correspondientes. El diseño de registro de evaluadores mediante un patrón de *registry* en la Capa 3 permite añadir nuevos tipos de *target* sin modificar el motor de evaluación central.

Esta extensibilidad opera principalmente sobre las capas 2 y 3, pero algunos métodos de extracción de información requieren ampliar también la interfaz expuesta por la Capa 1. La incorporación del monitor de red, por ejemplo, exigió agregar el aprovisionamiento de un contenedor *sidecar* de captura al `EnvironmentProvider`; un futuro monitor basado en eBPF probablemente requiera exponer un nuevo método para adjuntar programas al *cgroup* del contenedor vulnerable. La interfaz abstracta admite estos crecimientos siempre que se respete el principio de pasividad: la Capa 1 expone capacidades de observación, no las consume ni las interpreta.

Agnóstico a la implementación

Los educadores que crean desafíos no necesitan conocer los detalles de cómo funciona la detección; solo deben proporcionar una imagen vulnerable y un archivo YAML con las reglas declarativas. Esto reduce significativamente la barrera de entrada para crear contenido educativo. De igual forma, los sistemas vulnerables de Capa 1 no saben que están siendo monitoreados, lo cual es un principio crítico para la validez pedagógica del ejercicio: el entorno debe comportarse exactamente como lo haría en producción, sin cooperar con el sistema de detección. Este principio fue el aprendizaje más importante extraído de las pruebas de concepto previas, donde la lógica de detección estaba parcialmente implementada dentro del sistema vulnerable, violando la separación y limitando la aplicabilidad del enfoque.

No obstante, ser agnóstico a la implementación no implica ser independiente del tipo de aplicación. La eficacia de cada método de detección sigue dependiendo de las características del sistema vulnerable expuesto. La detección de inyección SQL (`log_pattern` + `network_payload`), por ejemplo, asume que el motor de base de datos elegido permite ex-

poner un *query log* legible por el monitor (caso de MySQL con `general_log`). Un escenario que use una base de datos que no exponga logs equivalentes obligaría al educador a definir condiciones de éxito por otras señales. Esta dependencia es propia del dominio del ejercicio y no del sistema de detección: el motor sigue ejecutando reglas declarativas sin conocer detalles de la aplicación, pero la elección de qué reglas son verificables sí depende de qué señales emite el sistema vulnerable.

***Trade-offs* de la arquitectura**

Esta arquitectura introduce complejidad adicional en comparación con un diseño monolítico, particularmente en la coordinación entre capas, la necesidad de definir interfaces claras y el *overhead* de comunicación entre componentes. Sin embargo, los beneficios en términos de mantenibilidad, portabilidad y capacidad de evolución del sistema justifican esta complejidad inicial, especialmente considerando que se espera que el sistema crezca con nuevos tipos de validadores, tecnologías de virtualización y escenarios de ejercicios a futuro.

3.1.2. Descripción de Capas

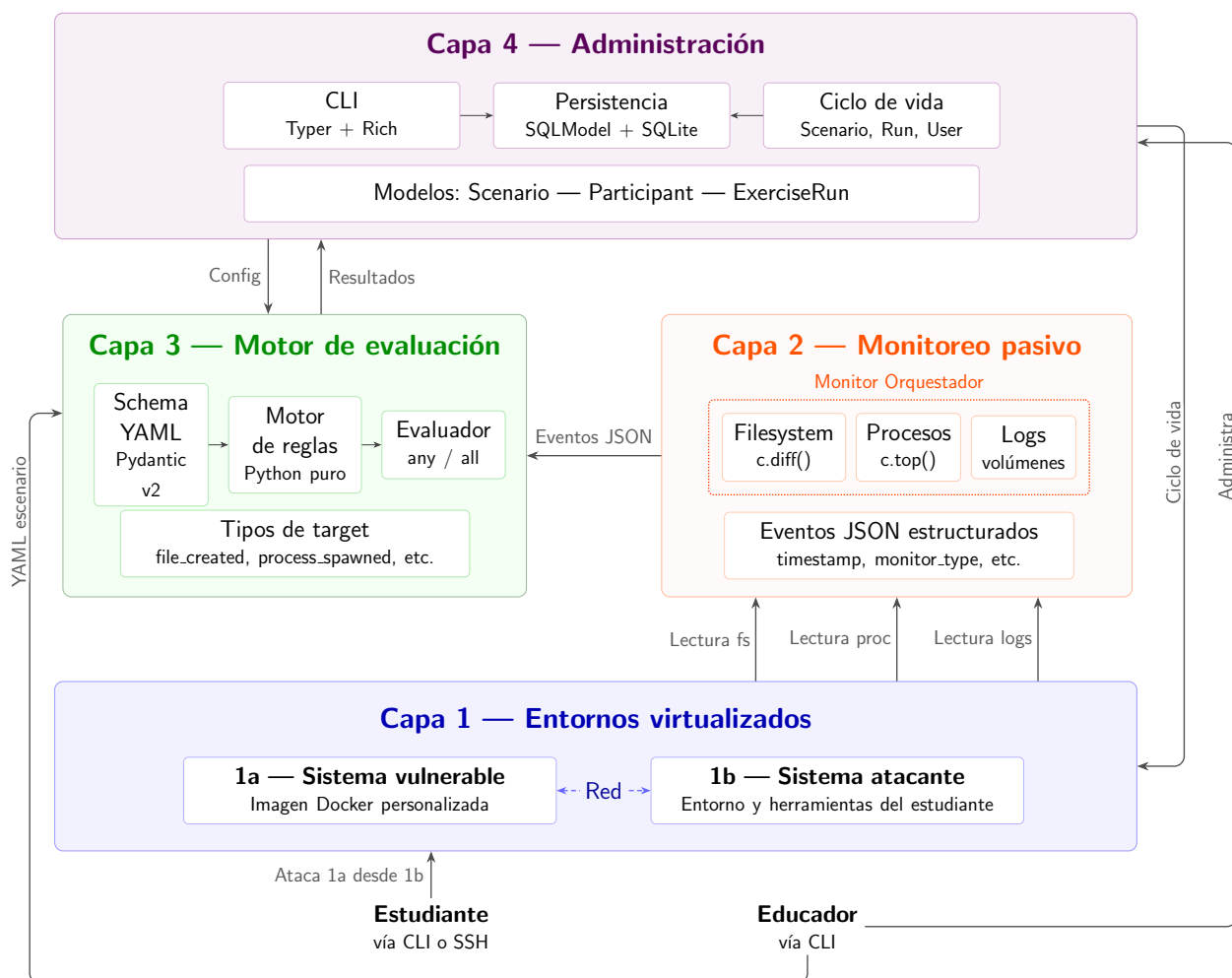


Figura 3.1: Arquitectura de cuatro capas de FlexiPwn.

Capa 1: Sistemas Virtualizados

Contiene en estado virtualizado todos los sistemas y redes que componen el escenario de ataque. Se divide en dos subcapas con roles diferenciados pero complementarios.

La **Capa 1a** representa el sistema vulnerable objetivo. Esta subcapa autocontiene todo el estado (archivos, memoria, procesos) necesario para determinar si un ataque fue exitoso. Es accesible al participante pero no comparte información de forma activa con otras capas del sistema, y no sabe que está siendo monitoreada.

La **Capa 1b** proporciona al participante un entorno con herramientas para ejecutar ataques. No tiene más acceso al sistema vulnerable que el necesario para ejecutar el ataque, típicamente conexión a la misma red interna.

Capa 2: Generación de Eventos

Tiene acceso de lectura externo al estado de los contenedores de Capa 1. Su única responsabilidad es generar un registro estructurado de eventos de seguridad detectables: cambios en el sistema de archivos, nuevos procesos, entradas de log de aplicación y tráfico de red observado. Su comportamiento es cercano al de un SIEM dedicado al escenario de ataque.

El principio fundamental de esta capa es la **pasividad total**: no ejecuta ningún comando dentro del contenedor vulnerable ni modifica su estado. Los mecanismos de observación son completamente externos:

- **Filesystem**: mediante `container.diff()` del Docker SDK, que retorna todos los archivos modificados, creados o eliminados respecto a la imagen original, sin montar volúmenes en el contenedor.
- **Procesos**: mediante `container.top()` con argumentos `-o pid,euid,ppid,cmd`, que lee la información de procesos desde el kernel del host sin ejecutar nada dentro del contenedor.
- **Logs de aplicación**: mediante lectura directa de archivos de log en el host, escritos por el contenedor a través de volúmenes montados en rutas explícitamente definidas en el YAML del escenario.
- **Red**: mediante un contenedor *sidecar* de captura (basado en `nicolaka/netshoot`) que comparte el *network namespace* del contenedor vulnerable. El *sidecar* ejecuta `tcpdump` y vuelca el resultado a un archivo en un *bind mount* del host. El monitor de red lee ese archivo desde fuera del contenedor vulnerable y emite los eventos correspondientes. El contenedor vulnerable nunca interactúa con `tcpdump` ni sabe que su tráfico se está observando.

Los cuatro monitores son coordinados por un *orquestador* que provee un único ciclo de *polling* por entorno, agrupa los eventos emitidos y los entrega en orden cronológico a la Capa 3. El detalle de esta coordinación, incluyendo el orquestador global que supervisa varios entornos en paralelo, corresponde al capítulo 4 de implementación.

Capa 3: Motor de Evaluación

Consume los eventos generados por la Capa 2 y evalúa condiciones de victoria definidas mediante reglas declarativas en archivos YAML. Determina cuándo un participante ha completado exitosamente un ejercicio sin requerir la entrada manual de *flags*. Esta capa no tiene acceso directo a los contenedores: todo su conocimiento del mundo exterior llega exclusivamente por los eventos de Capa 2.

Capa 4: Administración

Gestiona el ciclo de vida de los entornos: crear, reiniciar o destruir según sea necesario. Mantiene registro del progreso de todos los participantes según lo indicado por la Capa 3 y proporciona interfaces de línea de comandos para educadores y estudiantes.

3.2. Contratos entre Capas

Los contratos definen qué datos cruzan cada frontera, en qué formato, quién los produce y quién los consume. El objetivo es que cada capa pueda desarrollarse, testearse y reemplazarse de forma independiente siempre que respete estos contratos.

3.2.1. Capa 1 → Capa 2: Estado Observable

La Capa 1 no comunica nada activamente a la Capa 2. Este es un contrato implícito: la Capa 2 lee el estado de la Capa 1, y la Capa 1 no sabe que está siendo observada. La interfaz entre ambas es el estado observable del entorno virtualizado, accedido a través de tres canales descritos en la Sección anterior.

Toda interacción con los contenedores se canaliza a través de la interfaz abstracta `EnvironmentProvider`, que encapsula la tecnología de virtualización:

```
class EnvironmentProvider(ABC):
    def create(self, scenario_id, participant_id, image,
               attacker_image=None, ports=None, attacker_ports=None,
               log_paths=None, enable_network_capture=False,
               capture_filter="", ...) -> Environment
    def destroy(self, env_id) -> None
    def reset(self, env_id) -> None
    def get_status(self, env_id) -> Environment
    def exec_run(self, env_id, cmd, ...) -> ExecResult
    def get_filesystem_diff(self, env_id) -> list[dict]
    def get_processes(self, env_id) -> list[ProcessInfo]
    def cleanup_all(self) -> None
```

En el estado actual del sistema la única implementación concreta de esta interfaz es `DockerRootlessProvider`, que utiliza el SDK oficial de Docker (`docker-py`) sobre un *daemon* en modo *rootless*. Este proveedor materializa cada `Environment` como un conjunto de recursos Docker etiquetados con `flexipwn.managed=true` y `flexipwn.env_id`. Mantiene los nombres de contenedores y redes derivados del `env_id` para permitir reconciliación tras una caída del proceso. Una implementación alternativa (`PodmanProvider`, `KVMProvider`, etc.) solo debe respetar la firma de la interfaz para que las capas superiores puedan operarla sin cambios.

3.2.2. Capa 2 → Capa 3: Eventos Estructurados

La Capa 2 produce eventos JSON estructurados que la Capa 3 consume. Este es el contrato más crítico del sistema: define el lenguaje común entre la observación y la evaluación. Todos los eventos comparten un envelope común validado por Pydantic v2:

```
class MonitorEvent(BaseModel):
    timestamp: datetime
    monitor_type: Literal["filesystem", "process", "log", "network"]
    event_type: str
    env_id: str
    participant_id: str
    scenario_id: str
    details: dict[str, Any]
```

El campo `monitor_type` identifica la fuente del evento y `event_type` especifica la naturaleza del cambio. El campo `details` varía según el monitor que produce el evento.

Eventos de filesystem

Generados por el monitor de filesystem a partir de `container.diff()`. Los `event_type` posibles y los campos de `details` asociados son:

- `file_created`: archivo nuevo detectado respecto a la imagen original. `details` contiene `path` (ruta absoluta) y `kind` (valor 1, según la convención de `container.diff()`).
- `file_modified`: archivo existente en la imagen que fue modificado. `details` contiene `path` y `kind` (valor 0).
- `file_deleted`: archivo de la imagen original eliminado durante el ejercicio. `details` contiene `path` y `kind` (valor 2). Cabe notar que este tipo de evento no tiene un target correspondiente en el schema YAML: ningún escenario del sistema evalúa la eliminación de archivos como condición de éxito en el estado actual.

Eventos de procesos

Generados por el monitor de procesos a partir de `container.top()`. El único `event_type` implementado es:

- `process_spawned`: proceso nuevo detectado respecto al *baseline* capturado al iniciar el monitor. Los campos de `details` son `pid`, `euid` (effective UID del proceso), `ppid`, `cmd` (comando completo), `lstart` (timestamp de inicio del proceso en formato "Mon Oct 23 10:25:44 2023") y `process_id` (hash SHA-256 truncado a 12 caracteres de la combinación `pid:cmd`, que identifica unívocamente al proceso incluso ante reutilización de PID).

Eventos de logs

Generados por el monitor de logs mediante lectura directa de archivos en el host escritos a través de volúmenes Docker.

- **log_entry**: línea de log parseada exitosamente como JSON. **details** contiene **source_file** (ruta del archivo de log en el host) y **parsed** (objeto JSON completo de la línea detectada).

Eventos de red

Generados por el **NetworkMonitor** a partir de la captura de tráfico realizada por el contenedor *sidecar* basado en *nicolaka/netshoot* (descrito en la Sección 4.4.2). Se emiten dos tipos de eventos:

- **network_payload**: paquete observado con contenido ASCII imprimible relevante. **details** contiene **data** (texto ASCII imprimible extraído del payload), **src_ip**, **src_port**, **dst_ip**, **dst_port** y **flags** (banderas TCP del paquete, por ejemplo [P.] o [S.]).
- **network_connection**: conexión TCP establecida hacia un destino, detectada por el primer paquete SYN-ACK (Flags [S.]). **details** contiene **dst_ip** y **dst_port**.

La Capa 2 garantiza que todo evento emitido cumple el schema antes de enviarse, que los eventos se emiten en orden cronológico por monitor, y que no se emiten duplicados para el mismo cambio de estado.

3.2.3. Capa 3 → Capa 4: Resultados de Evaluación

La Capa 3 comunica a la Capa 4 los resultados de la evaluación de condiciones de éxito mediante dos estructuras Pydantic complementarias.

TargetResult representa el estado de evaluación de un objetivo individual:

```
class TargetResult(BaseModel):
    target_index: int
    target_type: str
    description: str
    matched: bool = False
    matched_at: datetime | None = None
    trigger_event: MonitorEvent | None = None
    children: list["TargetResult"] | None = None
```

El campo `trigger_event` contiene el `MonitorEvent` exacto que causó el *match*, lo que permite al educador reconstruir no solo qué objetivo se completó, sino qué acción concreta del estudiante lo disparó. Esta trazabilidad es uno de los valores pedagógicos diferenciales del sistema respecto a los sistemas de *flags*.

El campo `children` se utiliza únicamente cuando el target es un nodo lógico (`and`, `or` o `not`). Contiene los `TargetResult` de los sub-targets evaluados recursivamente, lo que permite a la Capa 4 mostrar al educador no solo qué rama lógica *matcheó*, sino qué sub-condiciones internas fueron las que la satisficieron.

`EvaluationResult` agrega el estado de todos los targets de un escenario para un participante:

```
class EvaluationResult(BaseModel):
    scenario_id: str
    participant_id: str
    env_id: str
    condition: str                    # "any" | "all"
    targets: list[TargetResult]
    completed: bool
    completed_at: datetime | None = None
    progress: float                  # hojas matcheadas / total hojas
```

El campo `progress` se calcula como la razón entre el número de *hojas* matcheadas y el total de hojas del árbol de targets del escenario. Las hojas son los targets atómicos (`file_created`, `process_running`, `network_payload`, etc.); los nodos lógicos (`and`, `or`, `not`) no cuentan como hoja: aportan estructura pero no se incluyen en el denominador del progreso. El campo `completed` es `True` si y solo si la condición (`any` o `all`) se satisface con el conjunto de targets de primer nivel marcados como `matched`. Cuando un target de primer nivel es un nodo lógico, su `matched` se determina recursivamente: `and` *matchea* si todos sus hijos *matchean*, `or` si al menos uno, `not` si su único hijo no *matchea*.

El `EvaluationEngine` invoca el callback `on_update` cada vez que un target cambia de estado o cuando `completed` pasa de `False` a `True`. Los logros son irreversibles dentro de un *run*: una vez que `matched` es `True`, no vuelve a `False`. La Capa 4 consume estos resultados para persistirlos en SQLite mediante la entidad `TargetResult` y para notificar al usuario a través de la CLI.

3.2.4. Capa 4 → Capa 1: Ciclo de Vida

La Capa 4 es la única capa que modifica el estado de la Capa 1, y lo hace exclusivamente a través de los métodos de la interfaz `EnvironmentProvider`: la materialización de un entorno, su reinicio, su detención o destrucción, y la reconciliación del estado persistido con los recursos reales del proveedor. Estas operaciones son invocaciones internas que la Capa 4 encadena para sostener los flujos expuestos al usuario; el detalle de cómo cada acción del educador o del

estudiante se traduce en una secuencia de invocaciones al `EnvironmentProvider` se describe en el capítulo de implementación.

Las consultas de estado (`get_status`, `get_processes`, `get_filesystem_diff`) son de solo lectura y, aunque la Capa 4 también las utiliza para producir vistas al usuario, conviven con el uso que de ellas hace la Capa 2 para generar eventos. La separación se preserva porque ambas capas consumen información sin modificar el entorno.

3.2.5. Educador → Capa 3: Archivo YAML del Escenario

El educador define un escenario mediante un único archivo YAML que la Capa 3 parsea y valida con Pydantic v2 antes de cualquier ejecución. Este archivo es la única pieza de configuración que el educador necesita escribir, además de la imagen Docker del sistema vulnerable.

La estructura completa del archivo es la siguiente:

```
title: str                # nombre del ejercicio (requerido)
description: str           # descripción del ejercicio (requerido)
author: str               # autor del escenario (requerido)
level: str                # beginner | intermediate | advanced
category: str             # pwning | web | database | forensics | reversing

environment:
  image: str               # imagen Docker para Capa 1a (requerido)
  attacker_image: str      # imagen Docker para Capa 1b (opcional)
  log_paths: list[str]     # rutas de logs a monitorear (opcional)
  ports: list[str]         # puertos extra del vulnerable
                          # "host:container" (opcional)
  capture_filter: str      # filtro para tcpdump, ej. "port 3306"
                          # (opcional, solo aplica si hay targets
                          # de tipo network_*)
  startup_delay_seconds: float # delay opcional antes de capturar
                          # el baseline si no hay HEALTHCHECK
                          # (null usa el default global)

hints:
  - str                   # pistas ordenadas para el estudiante (opcional)

targets:                  # lista de objetivos (requerido, mínimo 1)
  - type: str
    description: str
    # campos específicos según el tipo de target

condition: str            # any | all (requerido, aplica solo a la
                          # lista plana de targets, se ignora cuando
```

```

                                # los targets de primer nivel son nodos
                                # lógicos and/or/not)
timeout_seconds: int          # tiempo máximo en segundos (default: 1800)

```

Los tipos de target disponibles se dividen en *tipos atómicos*, que evalúan una condición concreta sobre eventos de la Capa 2, y *nodos lógicos*, que componen otros targets en árboles recursivos.

Tipos atómicos

file_created Detecta la creación de un archivo nuevo. Requiere **path** (ruta absoluta o directorio terminado en /). Acepta **pattern** (glob) cuando **path** es un directorio.

file_modified Detecta la modificación de un archivo existente en la imagen original. Requiere **path** (ruta absoluta).

process_running Detecta un proceso activo con características específicas. Requiere **euid** (effective UID esperado; 0 para root) y **cmd_contains** (substring en el comando del proceso). Acepta **ppid_cmd_contains** (substring en el comando del proceso padre) y **ancestor_contains** (substring en el comando de cualquier ancestro).

log_pattern Detecta una entrada de log que cumpla condiciones sobre campos parseados. Requiere **field_matches** (diccionario de campo → regex). El campo especial **raw_line** permite matchear contra la línea completa cuando el log es texto plano. Requiere que **environment.log_paths** declare al menos una ruta.

network_payload Detecta payloads de paquetes de red cuyo contenido ASCII imprimible coincida con una expresión regular. Requiere **field_matches** con la clave **data**; el matching se realiza con **re.IGNORECASE** sobre el texto extraído del paquete. Requiere que el escenario defina **attacker_image** y, opcionalmente, **capture_filter** en el bloque **environment**.

network_connection Detecta conexiones TCP establecidas (paquete SYN-ACK) hacia un destino. Requiere **dst_port**; acepta **dst_ip** para restringir a una IP específica.

Nodos lógicos

Los nodos lógicos componen otros targets en árboles recursivos y se identifican por su **type**. Sus sub-targets se definen en el campo **targets**, que puede contener tanto tipos atómicos como otros nodos lógicos.

and Matchea cuando todos sus sub-targets matchean. Requiere al menos dos sub-targets.

or Matchea cuando al menos un sub-target matchea. Requiere al menos dos sub-targets.

not Matchea cuando su único sub-target no matchea. Requiere exactamente un sub-target. No puede aparecer como target de primer nivel del escenario, ya que un escenario que se completara por la ausencia de un evento podría darse por exitoso sin acción alguna del estudiante; este caso se valida al cargar el YAML.

El campo de primer nivel **condition** (**any** o **all**) actúa como azúcar sintáctica para listas planas de targets atómicos: es equivalente a envolver la lista en un nodo **or** o **and** respectivamente.

A modo de ejemplo, el siguiente archivo YAML define un escenario de escalación de privilegios mediante **sudo vim**:

```
title: "Privilege escalation via sudo vim"
description: >
  El usuario ctfuser tiene permisos sudo sobre vim sin contraseña.
  Escala privilegios y crea evidencia de acceso root.
author: "Dylan Riquelme"
level: beginner
category: pwning

environment:
  image: "vuln-privesc"

hints:
  - "Revisa tus permisos sudo con: sudo -l"
  - "Vim puede ejecutar comandos del sistema con :!comando"

targets:
  - type: file_created
    path: "/root/"
    pattern: "*.txt"
    description: "Archivo .txt creado en directorio root"
  - type: file_modified
    path: "/etc/passwd"
    description: "Archivo de usuarios del sistema modificado"
  - type: process_running
    euid: 0
    cmd_contains: "/bin/bash"
    description: "Shell root activa"

condition: all
timeout_seconds: 1800
```

El schema se valida al momento de cargar el escenario, antes de cualquier ejecución. Los errores de validación producen mensajes que indican el campo problemático y el valor esperado, sin requerir ejecutar el sistema para descubrirlos.

3.3. Modelo de Datos

El estado del sistema se persiste en una base de datos SQLite gestionada mediante SQL-Model. La elección de SQLite responde al contexto de despliegue: una instalación autohostedada de escala pequeña a mediana que no justifica la operación de un servidor de base de datos independiente.

El modelo contempla cinco entidades principales. Todas usan identificadores `UUID` como clave primaria, generados automáticamente al persistir, lo que evita filtrar información temporal en los identificadores y simplifica la fusión de bases de datos entre instalaciones distintas.

Scenario almacena los metadatos del escenario cargado por el educador, incluyendo la ruta al archivo YAML, el contenido íntegro del YAML para reproducibilidad, y campos desnormalizados (`title`, `description`, `level`, `category`, `image`, `attacker_image`, `timeout_seconds`) para consultas directas sin reparsear el YAML.

Participant representa a un estudiante del sistema. Tiene `username` con índice único, evitando colisiones a nivel de base de datos. La contraseña se persiste como `hash` bcrypt, el texto plano solo se expone una vez al momento de crear o resetear el participante, y nunca se vuelve a recuperar.

ExerciseRun vincula a un participante con un escenario y registra el estado del ejercicio. Mantiene índices ordinarios sobre las claves foráneas `scenario_id` y `participant_id` para acelerar las consultas frecuentes (runs por participante, runs por escenario), y un índice único sobre `env_id` para garantizar que el identificador de entorno expuesto al participante no se repita entre runs. Persiste además los datos efímeros de acceso del estudiante (`attacker_ssh_port`, `attacker_ssh_username`, `attacker_ssh_password`) para que el educador pueda recuperar las credenciales en cualquier momento desde la CLI. La contraseña SSH se guarda en texto plano dentro del archivo SQLite del educador, con la trazabilidad documentada en el código sobre por qué este compromiso es aceptable para el contexto educativo. La validación de unicidad sobre el par (`scenario_id`, `participant_id`) para runs activos se hace a nivel aplicación, no de base de datos: el mismo participante puede tener múltiples runs históricos del mismo escenario, lo que permite reintentos sin borrar el historial previo.

TargetResult registra el estado de evaluación de cada objetivo individual dentro de un *run*, incluyendo el evento exacto que causó el *match* serializado como JSON. Tiene índice ordinario sobre `run_id` para recuperar eficientemente todos los resultados de un run.

RunEvent guarda el flujo completo de eventos del monitor asociados a un run (`monitor_type`, `event_type`, `details_json`, `timestamp`). Sirve como bitácora auditable del ejercicio, independiente de qué targets matcheen o no: permite reconstruir a posteriori la secuencia de acciones del estudiante. Tiene índice ordinario sobre `run_id`.

3.4. Aislamiento de Entornos

El aislamiento entre los entornos de práctica de distintos participantes opera en dos dimensiones complementarias: aislamiento de red y aislamiento de filesystem.

Modelo de red de doble capa

Cada entorno instancia dos redes Docker independientes con roles diferenciados. La red interna (`flexipwn-{env_id}`), creada con `internal=True`, conecta el sistema vulnerable y el sistema atacante entre sí sin permitir tráfico hacia el exterior. Esta configuración garantiza que un ejercicio de explotación activa no genere tráfico hacia redes externas ni hacia otros entornos del sistema. La red externa (`flexipwn-{env_id}-ext`), un bridge estándar sin restricciones, conecta exclusivamente el contenedor atacante al host. Esto permite que el participante acceda al entorno atacante mediante SSH desde su máquina, manteniendo al mismo tiempo el contenedor vulnerable completamente aislado del exterior.

El contenedor atacante opera en ambas redes simultáneamente: su interfaz en la red interna le permite resolver el nombre DNS del vulnerable (`flexipwn-{env_id}-vulnerable`) y establecer conexiones hacia él. Su interfaz en la red externa permite que los port bindings definidos en el YAML del escenario sean alcanzables desde el host. El contenedor vulnerable solo tiene presencia en la red interna.

El contenedor sidecar de captura de red (Sección 4.4.2) no se conecta a ninguna red Docker directamente: comparte el namespace de red del contenedor vulnerable mediante `--network container:{nombre_vulnerable}`, lo que le permite observar todo el tráfico del vulnerable sin introducir interfaces adicionales en la topología de red del entorno.

Aislamiento de filesystem

Los bind mounts efímeros descritos en la Sección 4 se crean con permisos `0o700`, accesibles únicamente por el proceso del daemon rootless. Al destruir el entorno, el árbol de directorios completo se elimina mediante `shutil.rmtree()`. Los directorios de captura de red, cuando existen, se eliminan en el mismo ciclo de destrucción, antes de detener los contenedores.

Capítulo 4

Implementación

Este capítulo describe las decisiones técnicas tomadas durante la implementación de FlexiPwn, organizadas según las capas de la arquitectura.

4.1. Stack Tecnológico

Las decisiones de *stack* tecnológico de FlexiPwn fueron tomadas en base a un contexto particular: el sistema debe ser autohospedable en hardware de recursos limitados, y suficientemente simple para que un educador no tenga que invertir demasiado tiempo configurando la infraestructura del sistema, para pueda operar y extender los escenarios de forma rápida. Esta sección describe los componentes seleccionados, organizados según las cuatro capas de la arquitectura. La justificación profunda de la tecnología de virtualización se desarrolla por separado en la Sección 4.2.

4.1.1. Lenguaje y gestión de dependencias

Python 3.12 es el lenguaje principal. La elección se sostiene en que es el lenguaje que más se domina y que coincide con tener un gran ecosistema de herramientas de infraestructura y orquestación, y de los lenguajes más utilizados en ciberseguridad [13].

La gestión de dependencias y entornos virtuales se realiza con `uv` [14], que reemplaza la combinación tradicional de `pip` y `venv` que agiliza y unifica instalación, sincronización y ejecución de scripts en una sola herramienta.

4.1.2. Capa 1: virtualización de entornos

Los entornos vulnerables y atacantes se ejecutan como contenedores Docker en modo *rootless*, gestionados desde Python con el SDK oficial `docker-py`. Se ~~decidió~~decidió utilizar

el modo *rootless* para minimizar la superficie de ataque del sistema: al no requerir privilegios de root ni un *daemon* centralizado, se reduce el riesgo de que una vulnerabilidad en el sistema de virtualización comprometa la máquina anfitriona. Esta decisión es un pilar de la seguridad central del proyecto y se justifica en detalle en la Sección 4.2. Toda la interacción con Docker se encapsula tras la interfaz abstracta `EnvironmentProvider` (ver capítulo 3), de modo que el resto del sistema no depende de la tecnología de virtualización concreta.

4.1.3. Capa 2: monitoreo pasivo

La Capa 2 no usa librerías de monitoreo externas: observa el estado de los contenedores exclusivamente a través del SDK de Docker y de lectura de archivos en el host. El monitor de **filesystem** usa `container.diff()`; el de **procesos**, `container.top()`; el de **logs** lee directamente los archivos que el contenedor escribe en *bind mounts*; y el de **red** parsea la salida de un contenedor *sidecar* basado en la imagen `nicolaka/netshoot` que ejecuta `tcpdump`. Esta implementación se describe en detalle más adelante en este capítulo.

4.1.4. Capa 3: motor de evaluación

Los escenarios se describen en archivos YAML parseados con PyYAML y validados con Pydantic v2. La separación entre *parsing* (PyYAML) y validación (Pydantic) es intencional: los errores de configuración se detectan con mensajes claros al cargar el escenario, no durante la ejecución. Pydantic v2 fue elegido por su integración nativa con SQLAlchemy y por el rendimiento de su núcleo en Rust.

El motor de evaluación de condiciones de éxito es código Python propio, sin dependencias externas. Los *frameworks* de reglas orientados a detección en producción (como Sigma o Yara) tienen una expresividad que excede los requerimientos de FlexiPwn y una curva de aprendizaje que complicaría la creación de escenarios. El motor implementa los tipos de target atómicos y los nodos lógicos **and/or/not** descritos en el capítulo 3, y es completamente independiente de la infraestructura de contenedores: sus pruebas corren en memoria, sin necesidad de Docker.

4.1.5. Capa 4: administración

La interfaz para educadores y estudiantes es una CLI construida con **Typer**, que genera comandos, subcomandos, validación de argumentos y páginas de ayuda a partir de las anotaciones de tipo de Python. **Rich** complementa a Typer con el *output* visual: tablas de escenarios, paneles de progreso e indicadores de estado. Sobre esta base, la administración opera como un *daemon* con un REPL interactivo construido con `prompt_toolkit`, que permite al educador operar el sistema en *foreground* o conectarse a un *daemon* en segundo plano; este componente se detalla en la sección 4.6.

El estado del sistema (escenarios, participantes, *runs* y resultados) se persiste en SQLite a

través de `SQLModel`, que combina `SQLAlchemy` como motor de base de datos con `Pydantic v2` como sistema de validación, permitiendo definir los modelos una sola vez. `SQLite` es apropiado para la escala de `FlexiPwn` (decenas a centenares de participantes) y reduce el despliegue a un único directorio con la plataforma y el archivo `.db`. Las contraseñas de los participantes se almacenan como *hash* `bcrypt`.

4.1.6. Testing

El *framework* de pruebas es `pytest`, con `pytest-mock` para los dobles de prueba. Los tests del motor de evaluación y de los *schemas* corren en memoria, sin `Docker`, lo que mantiene un ciclo de desarrollo ágil. Los tests de integración que requieren contenedores reales se marcan con `pytest.mark.integration` para ejecutarlos de forma opcional cuando el entorno tiene `Docker` disponible.

4.1.7. Resumen del stack

La Tabla 4.1 consolida los componentes con su versión mínima de referencia (según `pyproject.toml`), el rol que cumplen y la capa a la que pertenecen.

Tabla 4.1: Componentes del *stack* tecnológico de `FlexiPwn`.

Componente	Rol en <code>FlexiPwn</code>	Capa
Python ≥ 3.12	Lenguaje principal	Transversal
uv	Gestor de dependencias y entornos	Transversal
docker ≥ 7.0	SDK Python para el ciclo de vida de contenedores	Capa 1
pyyaml ≥ 6.0	<i>Parsing</i> de los <code>YAML</code> de escenarios	Capa 3
pydantic ≥ 2.0	Validación del <i>schema</i> de escenarios	Capa 3
typer ≥ 0.15	<i>Framework</i> de la CLI	Capa 4
rich ≥ 13.0	Tablas, paneles y <i>output</i> con color	Capa 4
prompt_toolkit ≥ 3.0	REPL interactivo del <i>daemon</i>	Capa 4
sqlmodel $\geq 0.0.14$	ORM sobre <code>SQLite</code> (persistencia)	Capa 4
bcrypt ≥ 4.0	<i>Hash</i> de contraseñas de participantes	Capa 4
pytest ≥ 8.0	<i>Testing</i> (con <code>pytest-mock</code>)	Transversal

El monitoreo de la Capa 2 no aparece en la tabla como dependencia externa porque se implementa enteramente sobre el SDK de `Docker` (`container.diff()`, `container.top()`) y lectura de archivos, sin librerías de observación adicionales.

4.1.8. Consideraciones de evolución

Dos decisiones del *stack* están marcadas para revisión futura. La primera es migrar el `EnvironmentProvider` de `Docker rootless` a **Podman rootless**, que al ser *daemonless* elimina el *daemon* centralizado como superficie de ataque, y que se podría lograr gracias a que

la interfaz abstracta hace que este cambio no afecte a las capas superiores. La segunda es complementar la CLI con una **interfaz web** para facilitar la administración del sistema y poder exponer de forma más visual el progreso de los estudiantes.

4.2. Decisión de Tecnología de Virtualización

FlexiPwn necesita instanciar entornos de práctica vulnerables para múltiples estudiantes en paralelo. Cada entorno debe ser aislado, reseteable y monitoreable desde Python. La elección de tecnología de virtualización impacta directamente en cinco dimensiones que se ponderaron según su importancia para el proyecto: seguridad del *host* (30 %), por tratarse de ejercicios con exploits activos; rapidez de inicialización (20 %), que define la experiencia del estudiante al pedir su entorno; simplicidad de implementación (20 %), que afecta la velocidad de desarrollo y la mantenibilidad; monitoreo programático (15 %), es decir, la facilidad para inspeccionar, por ejemplo, el *filesystem* y los logs desde Python; y portabilidad (15 %), para que el sistema funcione tanto en equipos educativos como en los servidores del laboratorio CLCERT.

Se evaluaron cuatro alternativas: Docker *rootful*, Docker *rootless*, Podman *rootless* y KVM/libvirt (máquinas virtuales completas). Se excluyeron gVisor y Kata Containers del análisis principal porque, si bien son opciones válidas, añaden una complejidad operativa que escapa el alcance educativo del proyecto en su fase actual.

4.2.1. Alternativas evaluadas

Docker *rootful* es la configuración por defecto de Docker Engine: un *daemon* con privilegios de root en el *host*. Su SDK para Python (`docker-py`) es maduro y muy documentado, pero su modelo de seguridad es inadecuado para ejercicios de ataque. Tectonic, la plataforma de *cyber range*, advierte explícitamente que en modo privilegiado un usuario que obtenga root dentro de un contenedor puede obtener root en el *host* [12]. Este riesgo no es teórico: las vulnerabilidades CVE-2025-31133, CVE-2025-52565 y CVE-2025-52881 en *runc* (noviembre de 2025) permiten escape de contenedor y root en el *host* mediante manipulación de *symlinks*, y el patrón se repite históricamente [15].

Docker *rootless* ejecuta tanto el *daemon* como los contenedores dentro de un *user namespace*. Si un atacante escapa del contenedor, solo obtiene los permisos del usuario de *host* que ejecuta el *daemon*, nunca root [16]. El SDK de Python es idéntico al de *rootful*.

Podman *rootless* tiene una arquitectura *daemonless*: cada comando crea un proceso hijo sin un *daemon* central con privilegios, lo que elimina la superficie de ataque que representa un *daemon* compartido. Es *rootless* por diseño desde su origen y expone una API compatible con la de Docker, utilizable mediante `docker-py` o el cliente nativo `podman-py` [17, 18].

KVM/libvirt ofrece el mayor aislamiento posible, un kernel separado por máquina virtual, pero con un costo prohibitivo para el caso de uso: tanto el arranque de cada instancia

como su consumo de memoria son significativamente mayores que los de un contenedor [19], y la operación a escala suele requerir herramientas como Terraform, Packer y Ansible.

4.2.2. Comparación ponderada

La Tabla 4.2 resume el puntaje de cada alternativa en una escala de 1 a 5 por criterio, multiplicado por el peso respectivo. Los valores son cualitativos transformados a escala ordinal: representan la posición relativa de cada opción en el contexto específico de FlexiPwn (educación, escala pequeña a mediana, monorepo Python, despliegue autohospedable), no mediciones de *benchmark*.

Tabla 4.2: Comparación ponderada de tecnologías de virtualización.

Criterio (peso)	D. rootful	D. rootless	Podman	KVM
Seguridad (30 %)	1 / 0.30	4 / 1.20	5 / 1.50	5 / 1.50
Startup (20 %)	5 / 1.00	4 / 0.80	4 / 0.80	2 / 0.40
Simplicidad (20 %)	5 / 1.00	4 / 0.80	4 / 0.80	2 / 0.40
Monitoreo (15 %)	5 / 0.75	5 / 0.75	5 / 0.75	3 / 0.45
Portabilidad (15 %)	5 / 0.75	4 / 0.60	4 / 0.60	2 / 0.30
Total	3.80	4.15	4.45	3.05

4.2.3. Decisión: Docker *rootless* con interfaz abstracta

FlexiPwn utiliza Docker *rootless* como tecnología de virtualización principal, expuesto a través de la interfaz abstracta `EnvironmentProvider` descrita en el Capítulo 3. La decisión se apoya en los tres criterios de mayor peso. En **seguridad**, el modo *rootless* elimina el vector de escape hacia root en el *host*, que es el riesgo más crítico en una plataforma con ejercicios de *privilege escalation*; KVM ofrecería un aislamiento mayor, pero la diferencia es marginal en un entorno educativo controlado donde los participantes son estudiantes y no atacantes externos adversariales. En **rapidez de inicialización**, los contenedores arrancan en menos de un segundo con la imagen precargada, frente a los 5 a 30 segundos de una VM, diferencia decisiva cuando 30 o más estudiantes crean sus entornos al inicio de una clase. En **simplicidad**, `docker-py` es la API de orquestación de contenedores más madura y documentada disponible, lo que acelera el desarrollo dentro de los plazos del proyecto.

Hay que notar que Podman *rootless* obtuvo el puntaje ponderado más alto (4.45 frente a 4.15) y es arquitectónicamente más sólido al ser *daemonless*. La razón para no elegirlo como *backend* principal es pragmática: `podman-py` es funcional pero aún en desarrollo activo, con diferencias sutiles respecto a `docker-py` en operaciones de *streaming* de logs y *stats*, y la documentación y comunidad de `docker-py` es considerablemente mayor. En términos prácticos, ambas alternativas ofrecen garantías de seguridad equivalentes para los ejercicios de FlexiPwn. La diferencia arquitectónica es significativa en producción a gran escala, pero marginal para una instalación educativa de algunas decenas de usuarios concurrentes. La interfaz abstracta permite incorporar Podman como *backend* alternativo en una iteración futura sin modificar las capas superiores.

4.2.4. Trabajo futuro en aislamiento

Existen tres líneas de evolución posibles, donde las últimas dos apuntan a vulnerabilidades más sofisticadas. La primera es implementar un `PodmanProvider`, mejora natural en seguridad arquitectónica por su base *rootless*. La segunda es usar gVisor (`runsc`) como *runtime* alternativo para ejercicios con vulnerabilidades más delicadas: añade un kernel en espacio de usuario que intercepta *syscalls* con un *overhead* mucho menor que una VM, aunque implementa solo una parte de las *syscalls* de Linux, lo que puede causar incompatibilidades con ciertos exploits. La tercera es Kata Containers para ejercicios de *kernel exploitation*, donde Docker *rootless* no basta porque el kernel del *host* sigue siendo compartido. Kata ejecuta los *workloads* en una VM ligera con su propio kernel, resolviendo ese límite a cambio de un arranque algo mayor [20].

4.3. Capa 1: Orquestador de Contenedores

La Capa 1 está implementada por la clase `DockerRootlessProvider`, la única aplicación concreta de la interfaz abstracta `EnvironmentProvider` hasta el momento introducida en el Capítulo 3. Este *provider* encapsula todas las llamadas al SDK de Docker (`docker-py`) y materializa cada `Environment` como un conjunto de recursos Docker (redes, contenedores y *bind mounts*) con identificación y etiquetado uniforme, de modo que las capas superiores puedan operar entornos sin conocer detalles del *runtime*. Esta sección describe los aspectos de implementación y presenta las justificaciones que la llevaron a su estado actual.

4.3.1. Detección del socket Docker

`DockerRootlessProvider` resuelve la ubicación del socket Docker al construirse, sin requerir configuración explícita en la mayoría de los casos. La detección sigue tres pasos en orden de prioridad: primero respeta la variable de entorno `DOCKER_HOST` si está definida, permitiendo que el educador apunte a un socket personalizado. De no presentarla, busca `$XDG_RUNTIME_DIR/docker.sock`, que es la ubicación estándar en sistemas Linux modernos, y como último recurso intenta `/run/user/{uid}/docker.sock`, la ruta por defecto de la instalación *rootless* de Docker. Si ninguna existe, se levanta un `SocketNotFoundError` con un mensaje que indica al usuario las rutas que se intentaron, evitando errores opacos del SDK.

4.3.2. Identificación y etiquetado de recursos

Cada entorno recibe un identificador único `env_id` de la forma `run-XXXXXXX` (el prefijo “run” y ocho caracteres hexadecimales derivados de un UUID), del que se derivan los nombres de otros recursos asociados: `flexipwn-{env_id}-vulnerable` y `flexipwn-{env_id}-attacker` para los contenedores, y `flexipwn-{env_id}` y `flexipwn-{env_id}-ext` para las redes interna y externa. Esta convención permite recuperar

cualquier recurso a partir del `env_id` persistido en la base de datos sin mantener un mapeo aparte.

Todos los recursos creados por la plataforma se etiquetan con `flexipwn.managed=true` más un conjunto de etiquetas contextuales `flexipwn.env_id`, `flexipwn.scenario_id` y `flexipwn.participant_id`. Estas etiquetas son la base de la operación de limpieza `cleanup_all`, que recorre los recursos del *daemon* filtrando por la etiqueta principal y elimina cualquier entorno huérfano que haya sobrevivido a una caída del proceso administrador, permitiendo recuperar la consistencia entre el estado persistido en SQLite y el estado real de Docker sin afectar recursos ajenos a FlexiPwn.

4.3.3. Creación con *rollback*

La operación `create()` levanta cuatro recursos sucesivamente: el directorio base de *bind mounts*, las redes interna y externa, el contenedor vulnerable, el contenedor atacante y el *sidecar* de captura de red. Un fallo a mitad de camino dejaría recursos huérfanos en Docker y archivos sin uso en el *host*, lo que con el tiempo contaminaría el sistema y dificultaría el diagnóstico de posibles errores.

Para evitarlo, el método mantiene un conjunto de banderas booleanas, una por tipo de recurso, que se activan a medida que cada paso completa con éxito. Cualquier excepción captura el flujo en un único bloque `except` que invoca `rollback`, encargado de deshacer exclusivamente lo que estaba creado en el momento del fallo. En definitiva, `create()` puede terminar de 2 formas: o retorna un `Environment` completamente funcional, o lanza la excepción original con todos los recursos parciales eliminados.

4.3.4. Estrategia de *baseline* para los monitores

Los monitores de Capa 2 necesitan distinguir entre los cambios que el contenedor produce durante su inicialización (instalación de paquetes, arranque de servicios, creación de archivos temporales) y los cambios provocados por el estudiante durante el ejercicio. Para esto, el *provider* captura un *baseline* del estado del contenedor una vez que su inicialización se considera concluida.

La estrategia de detección de ese momento es híbrida y se elige automáticamente según las capacidades de la imagen. Si el contenedor vulnerable declara un `HEALTHCHECK`, el *provider* consulta periódicamente el estado de salud reportado por Docker hasta que alcance `healthy`. Esta forma es la preferida porque elimina la incertidumbre de un tiempo de espera fijo y se ajusta al tiempo real de arranque de cada imagen. Si la imagen no define un `HEALTHCHECK`, el *provider* recurre al modo `delay`: espera un intervalo configurable (con valor por defecto y ajustable por escenario mediante `startup_delay_seconds`) antes de tomar el *baseline*. Si el `HEALTHCHECK` existe pero no llega a `healthy` dentro del *timeout* configurado, el *provider* toma el *baseline* de todas formas y emite una advertencia, priorizando la disponibilidad del entorno por sobre la garantía de arranque limpio.

El *baseline* resultante se guarda en disco, junto con la estrategia que se usó para capturarlo. Esto permite que el *provider* se reinicie sin perder la referencia, evitando que reinicios del *daemon* marquen como cambios del estudiante todo lo que el contenedor escribió durante su arranque original.

4.4. Capa 2: Monitoreo Pasivo

4.4.1. Limitaciones del Monitoreo por Polling

El monitor de procesos consulta `container.top()` cada dos segundos. Procesos que nacen y terminan dentro de ese intervalo son invisibles para el sistema. Los vectores no detectables en el estado actual incluyen: procesos efímeros con duración menor a dos segundos, técnicas de *PPID spoofing*, y ataques *fileless* mediante llamadas al sistema como `ptrace` o `memfd_create`. Para el alcance educativo del proyecto, este nivel de detección es aceptable dado que los ejercicios no requieren detectar procesos sub-segundo ni técnicas de evasión avanzadas esperables en un atacante universitario.

De forma análoga, `container.diff()` retorna una instantánea del estado acumulado del filesystem desde el inicio del contenedor. Para distinguir cambios del sistema de inicialización de cambios realizados por el estudiante, se captura un *baseline* del *diff* una vez que el contenedor está estable. Si la imagen tiene un `HEALTHCHECK` configurado, el sistema espera hasta que el contenedor reporte estado `healthy` antes de capturar el *baseline*; de lo contrario, espera un delay configurable (por defecto 3 segundos) como mecanismo de respaldo.

4.4.2. Monitor de Red

Para escenarios que requieren observar tráfico de red, la Capa 2 instancia un cuarto monitor: `NetworkMonitor`. A diferencia de los tres monitores anteriores, este monitor depende de un contenedor sidecar que comparte el namespace de red del sistema vulnerable.

Contenedor sidecar

Al crear el entorno, si el escenario define al menos un target de tipo `network_*`, `DockerRootlessProvider` lanza un contenedor adicional basado en la imagen `nicolaka/netshoot` con la siguiente configuración:

- **Namespace de red compartido:** mediante `--network container:{vulnerable}`, el sidecar comparte exactamente el mismo namespace de red que el vulnerable. Esto hace visible todo el tráfico del vulnerable desde dentro del sidecar, incluyendo comunicaciones por la interfaz de loopback (`127.0.0.1`), que de otro modo no serían capturables desde una perspectiva externa.

- **Comando de captura:** `tcpdump -i any -A -n -l`, con un filtro opcional definido en el campo `environment.capture_filter` del YAML del escenario (por ejemplo, `port 3306` para restringir la captura a tráfico MySQL).
- **Salida en bind mount:** la captura se escribe en un archivo `traffic.txt` en un directorio del host con permisos `0o700`, al que solo tiene acceso el proceso de FlexiPwn.

El uso de `-n` desactiva la resolución de nombres, forzando IPs numéricas en el output y evitando que el parser del monitor falle ante hostnames como `localhost`. El flag `-l` activa el line-buffering de `tcpdump`, reduciendo la latencia entre la escritura del paquete y su disponibilidad en el archivo del host.

Parsing packet-based

`NetworkMonitor` lee el archivo `traffic.txt` de forma incremental en cada ciclo de polling, procesando el output de `tcpdump` como unidades de paquete completo en lugar de línea por línea. Esta decisión es necesaria porque el output de `tcpdump -A` en modo `-i any` mezcla bytes ASCII del payload con bytes binarios de los headers TCP/IP, y el carácter `0x0a` (LF) puede aparecer dentro de los headers, partiendo artificialmente el payload en múltiples líneas si se procesa con `splitlines()`.

El monitor detecta las cabeceras de paquete mediante una expresión regular que acepta el formato de `-i any` (que incluye el nombre de interfaz y dirección entre el timestamp y la IP) y extrae de ellas las IPs y puertos de origen y destino. Las líneas entre cabeceras se acumulan en un buffer de payload. Cuando se detecta una nueva cabecera, el buffer del paquete anterior se procesa: se extrae todo el texto en rango ASCII imprimible (`0x20--0x7e`), y si el resultado supera los cuatro caracteres se emite un `MonitorEvent` de tipo `network_payload` con el texto extraído y los metadatos del paquete. Adicionalmente, si la cabecera contiene `Flags [S.]`, se emite un evento `network_connection` con la IP y puerto de destino.

Una implicación importante del modelo packet-based es que el último paquete de una ráfaga de tráfico corta podría quedar atrapado en el buffer si no llega una cabecera posterior que dispare su procesamiento. Para evitar esto, al final de cada ciclo de polling el monitor procesa el paquete en curso si el buffer no está vacío, sin esperar al siguiente ciclo.

4.5. Capa 3: Motor de Evaluación

Los tipos de target implementados en el estado actual del sistema son:

`file_created`, `file_modified` Operan sobre eventos del monitor de filesystem. Permiten detectar creación o modificación de archivos en rutas absolutas o mediante patrones glob.

`process_running` Opera sobre eventos del monitor de procesos. Detecta procesos activos por effective UID y substring en el comando.

log_pattern Opera sobre eventos del monitor de logs. Aplica un diccionario de campo→regex sobre los campos de la entrada de log parseada como JSON.

network_payload Opera sobre eventos **network_payload** del **NetworkMonitor**. Aplica un diccionario de campo→regex sobre el campo **data** del evento, que contiene el texto ASCII imprimible extraído del payload del paquete. El matching se realiza con **re.IGNORECASE**, de modo que el educador no necesita contemplar variaciones de capitalización en los patrones.

network_connection Opera sobre eventos **network_connection** del **NetworkMonitor**. Detecta conexiones TCP establecidas (paquete SYN-ACK) hacia un puerto de destino específico, con filtro opcional por IP de destino.

and, or, not Nodos lógicos recursivos que permiten componer condiciones complejas sobre cualquier combinación de targets atómicos. El campo **condition: any|all** del escenario actúa como azúcar sintáctica para listas planas de targets sin nodos lógicos.

La inspección de consultas SQL no requiere un evaluador con acceso a la base de datos: se realiza sobre el tráfico de red mediante **network_payload** con un filtro **capture_filter: "port 3306"**, que captura las consultas directamente del tráfico TCP entre la aplicación y el motor de base de datos, preservando la pasividad del monitoreo.

4.6. Capa 4: Administración

Capítulo 5

Validación

5.1. Evaluación

Capítulo 6

Conclusión

Bibliografía

- [1] [OWASP. OWASP Top 10 2025.](https://owasp.org/Top10/es/2025/0x00_2025-Introduction/) https://owasp.org/Top10/es/2025/0x00_2025-Introduction/, 2025. Visitado el 2025-11-12.
- [2] [SANS Institute. Be Ready, Be Resilient: Hands-On Cybersecurity Training & Skill Validation for Real-World Threats.](https://www.sans.org/blog/be-ready-be-resilient-hands-on-cybersecurity-training-skill-validation-for-real-world-threats) <https://www.sans.org/blog/be-ready-be-resilient-hands-on-cybersecurity-training-skill-validation-for-real-world-threats>, 2025. Visitado el 2025-09-20.
- [3] [TryHackMe. TryHackMe — Cyber Security Training.](https://tryhackme.com/) <https://tryhackme.com/>, 2025. Visitado el 2025-08-18.
- [4] [Hack The Box. Hack The Box: The #1 Cybersecurity Performance Center.](https://www.hackthebox.com/) <https://www.hackthebox.com/>, 2025. Visitado el 2025-08-18.
- [5] [PortSwigger. Web Security Academy: Free misc Training from PortSwigger.](https://portswigger.net/web-security/) <https://portswigger.net/web-security/>, 2025. Visitado el 2025-08-18.
- [6] [DVWA. Damn Vulnerable Web Application \(DVWA\).](https://github.com/digininja/DVWA) <https://github.com/digininja/DVWA>, 2025. Visitado el 2025-08-18.
- [7] [CTFd LLC. CTFd: The Easiest Capture The Flag Framework.](https://ctfd.io/) <https://ctfd.io/>, 2025. Visitado el 2025-08-18.
- [8] [RootTheBox. RootTheBox. A Game of Hackers \(CTF Scoreboard & Game Manager\).](https://github.com/moloch--/RootTheBox) <https://github.com/moloch--/RootTheBox>, 2025. Visitado el 2025-08-25.
- [9] [Carnegie Mellon University. picoCTF - CMU Cybersecurity Competition.](https://www.picoctf.org/) <https://www.picoctf.org/>, 2025. Visitado el 2025-08-25.
- [10] [CyberRangeCZ. CyberRangeCZ.](https://github.com/cyberrange cz) <https://github.com/cyberrange cz>, 2025. Visitado el 2025-08-25.
- [11] [EDURange. EDURange.](https://edurange.org/) <https://edurange.org/>, 2025. Visitado el 2025-08-25.
- [12] [Tectonic Cyber Range. Tectonic Cyber Range.](https://www.fing.edu.uy/inco/proyectos/tectonic) <https://www.fing.edu.uy/inco/proyectos/tectonic>, 2025. Visitado el 2025-08-25.
- [13] [Hack The Box. Best Programming Languages for Cybersecurity.](https://www.hackthebox.com/blog/best-programming-languages-for-cybersecurity) <https://www.hackthebox.com/blog/best-programming-languages-for-cybersecurity>, 2023. Visitado el 2026-05-24.

- [14] [Astral. uv: A modern Python package and virtual environment manager.](https://docs.astral.sh/uv/) <https://docs.astral.sh/uv/>. Visitado el 2026-05-24.
- [15] [Sysdig. CVE-2025-31133, CVE-2025-52565, CVE-2025-52881: runc container escape vulnerabilities.](https://www.sysdig.com/blog/runc-container-escape-vulnerabilities) <https://www.sysdig.com/blog/runc-container-escape-vulnerabilities>, 2025. runc 1.2.8+. Visitado el 2026-05-25.
- [16] [Docker. Rootless mode.](https://docs.docker.com/engine/security/rootless/) <https://docs.docker.com/engine/security/rootless/>, 2025. Visitado el 2026-05-25.
- [17] [Containers. podman-py: Python bindings for Podman.](https://github.com/containers/podman-py) <https://github.com/containers/podman-py>, 2025. v5.7.0. Visitado el 2026-05-25.
- [18] [DEV Community. Docker vs Podman: An In-Depth Comparison \(2026\).](https://dev.to/mechcloud_academy/docker-vs-podman-an-in-depth-comparison-2025-2eia) https://dev.to/mechcloud_academy/docker-vs-podman-an-in-depth-comparison-2025-2eia, 2025. Visitado el 2026-05-25.
- [19] [W. Felter, A. Ferreira, R. Rajamony, and J. Rubio. An updated performance comparison of virtual machines and Linux containers. In 2015 IEEE International Symposium on Performance Analysis of Systems and Software \(ISPASS\). IEEE, 2015. pp. 171–172.](#)
- [20] [Northflank. Kata Containers vs gVisor.](https://northflank.com/blog/kata-containers-vs-gvisor) <https://northflank.com/blog/kata-containers-vs-gvisor>, 2026. Visitado el 2026-05-25.
- [21] [NepJag. CLCERT: pocFlexiPwn.](https://github.com/NepJag/pocFlexiPwn) <https://github.com/NepJag/pocFlexiPwn>, 2025. Visitado el 2025-10-17.
- [22] [NepJag. CLCERT: FlexiPwn.](https://github.com/NepJag/FlexiPwn) <https://github.com/NepJag/FlexiPwn>, 2026. Visitado el 2026-03-04.

Apéndice A

Anexo

Quisque facilisis auctor sapien. Pellentesque gravida hendrerit lectus. Mauris rutrum sodales sapien. Fusce hendrerit sem vel lorem. Integer pellentesque massa vel augue. Integer elit tortor, feugiat quis, sagittis et, ornare non, lacus. Vestibulum posuere pellentesque eros. Quisque venenatis ipsum dictum nulla. Aliquam quis quam non metus eleifend interdum. Nam eget sapien ac mauris malesuada adipiscing. Etiam eleifend neque sed quam. Nulla facilisi. Proin a ligula. Sed id dui eu nibh egestas tincidunt. Suspendisse arcu.